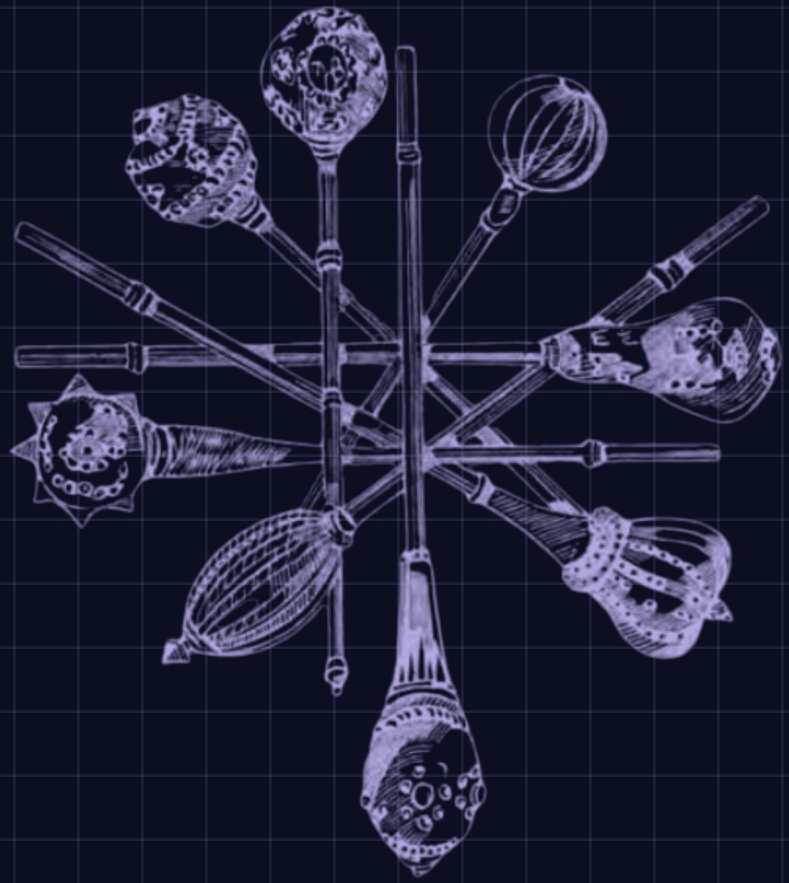
Іван Гокін



GRC101: професійна орієнтація

Що таке GRC, з чого складається робота і як у неї увійти

ДАВАЙТЕ ПОЗНАЙОМИМОСЬ

Іван Гокін

Врядування, ризики й відповідність у кібербезпеці

ПРО ЛЕКЦІЮ

Професійна орієнтація: що таке GRC, з чого складається робота і куди в ній рости.

СТАТУС

Роль	**IT-аудитор**
Сертифікація	**CISA**
Досвід	**5+ років**
Сфера	**Консалтинг та аудит**
Зв’язок	LinkedIn · GitHub

ПЛАН

Що ми обговоримо

1

Врядування

Що таке GRC, системи управління, СУІБ

2

Ризики

Процес, сценарії, реєстр і ризик-апетит

3

Відповідність

Джерела вимог, інтеграція, судова практика

4

Аудит

Призначення, незалежність, відповідальність

5

Професія

Ринок, навички, сертифікації, GRC Engineering

I

Врядування

Що таке GRC, системи управління і як побудувати СУІБ

ВИЗНАЧЕННЯ

Що таке GRC

Governance

ВРЯДУВАННЯ

Спроможність організації досягати бізнес-цілей

Risk

УПРАВЛІННЯ РИЗИКОМ

Стійкість організації до внутрішніх і зовнішніх чинників

Compliance

ВІДПОВІДНІСТЬ

Відповідність вимогам законодавства, третіх сторін тощо

> «GRC — це інтегрований набір можливостей, які дозволяють організації досягати принципової продуктивності: надійно досягати цілей, долати невизначеність і діяти чесно». — OCEG

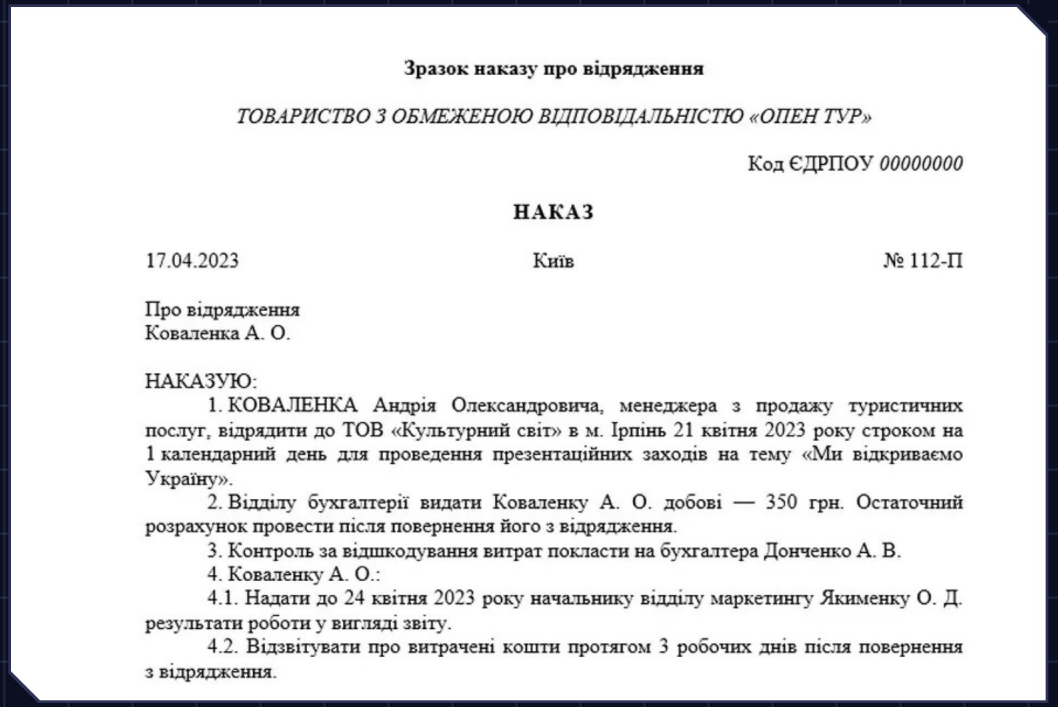
Що таке система управління?

> Сукупність взаємопов’язаних або взаємодіючих елементів організації для встановлення намірів і цілей, а також процесів для досягнення цих цілей.

ДСТУ ISO 9001:2015

Накази, укази, папери...

- Самі по собі накази теж є системою управління.
- Але без процесного підходу вони не є надійним способом управління.
- Як наступний керівник знатиме про всі чинні накази?



Зразок наказу про відрядження

ТОВАРИСТВО З ОБМЕЖЕНОЮ ВІДПОВІДАЛЬНІСТЮ «ОПЕН ТУР»

Код ЄДРПОУ *00000000*

НАКАЗ

17.04.2023 Київ № 112-П

Про відрядження
Коваленка А. О.

НАКАЗУЮ:

1. КОВАЛЕНКА Андрія Олександровича, менеджера з продажу туристичних послуг, відрядити до ТОВ «Культурний світ» в м. Ірпінь 21 квітня 2023 року строком на 1 календарний день для проведення презентаційних заходів на тему «Ми відкриваємо Україну».
2. Відділу бухгалтерії видати Коваленку А. О. добові — 350 грн. Остаточний розрахунок провести після повернення його з відрядження.
3. Контроль за відшкодування витрат покласти на бухгалтера Донченко А. В.
4. Коваленку А. О.:

4.1. Надати до 24 квітня 2023 року начальнику відділу маркетингу Якименку О. Д. результати роботи у вигляді звіту.

4.2. Відзвітувати про витрачені кошти протягом 3 робочих днів після повернення з відрядження.

ПРОЦЕСНИЙ ПІДХІД

Системи управління тримаються на процесах

Джерела входів

Попередні процеси

Постачальники, замовники, інші зацікавлені сторони

Входи

Матерія, енергія, інформація

Матеріали, ресурси, вимоги

Дії

Мають початок і кінець

Виходи

Матерія, енергія, інформація

Продукція, послуга, рішення

Одержувачі виходів

Наступні процеси

Замовники, інші зацікавлені сторони

Контролі для моніторингу та вимірювання ефективності

Джерело: ДСТУ ISO 9001:2015

Типи стандартів на прикладі ISO

Системи управління

ISO 9001:2015
Quality management systems

ISO/IEC 27001:2022
Information security management systems

ISO 14001:2015
Environmental management systems

Галузеві системи управління

ISO 13485:2016
Medical devices — Quality management systems

ISO 22163:2023
Railway applications — Railway quality management system

Настанови щодо систем управління

ISO 45003:2021
Psychological health and safety at work

ISO 19011:2018
Guidelines for auditing management systems

Стандарти управління

ISO 26000:2010
Guidance on social responsibility

ISO 31000:2018
Risk management — Guidelines

В Україні стандарти ISO зазвичай адаптуються як ДСТУ; придбати їх можна, наприклад, у ДП «УкрНДНЦ». Джерело: iso.org

Інтегрована система управління поєднує інші

Інтегрована система управління

- Система управління якістю
- Система управління інформаційною безпекою
- Система управління ризиком
- та інші...

Як побудувати СУІБ: п’ять етапів

01	**Ініціювання**	Визначити команду · Отримати підтримку вищого керівництва · Визначити ролі й обов’язки
02	**Визначення**	Погодити зрозумілі й досяжні цілі · Визначити обсяг СУІБ · Оцінити прогалини · Розробити політику ІБ і процедури
03	**Оцінювання**	Визначити інформаційні активи · Оцінити ризики · Визначити мінімальні вимоги до безпеки активів · Сформувати заяву про застосовність
04	**Розробка**	Впровадити план обробки ризиків · Застосувати контролі · Відстежувати, оцінювати й погоджувати
05	**Підготовка**	Готуватись до сертифікації чи аудиту · Внутрішні аудити й перегляд керівництвом · Зовнішній аудит

Вище керівництво має показати зобов’язання щодо СУІБ

- ✓ Політика й цілі ІБ сумісні зі стратегією організації
- ✓ Вимоги СУІБ інтегровані в процеси організації
- ✓ Ресурси, потрібні для СУІБ, доступні
- ✓ Люди, що забезпечують ефективність СУІБ, призначені й мають підтримку
- ✓ Організація знає, наскільки важливі ефективна ІБ і відповідність вимогам СУІБ
- ✓ СУІБ досягає запланованих результатів
- ✓ Інші керівники отримують підтримку, щоб проявляти лідерство у своїх сферах
- ✓ Постійне вдосконалення має підтримку

Джерело: ISO/IEC 27001, п. 5.1 «Лідерство та зобов’язання»

СТАНДАРТИ

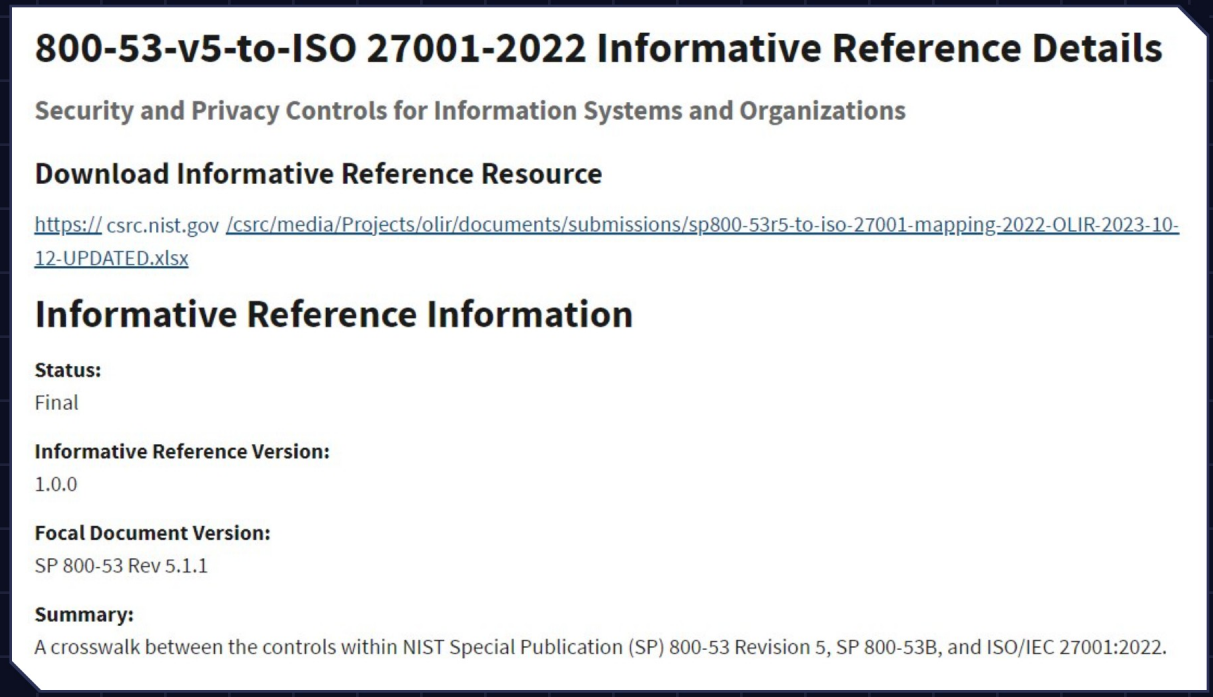
СУІБ можна будувати на різних стандартах

Джерело: ComplianceForge

Але яка ж родина стандартів буде кращим варіантом?

Один стандарт не заважає використовувати інші

- Стандарти співвідносяться один з одним через так звані mapping, або crosswalk.
- Приклад — співвідношення ISO/IEC 27001 та NIST SP 800-53 від NIST.



800-53-v5-to-ISO 27001-2022 Informative Reference Details

Security and Privacy Controls for Information Systems and Organizations

Download Informative Reference Resource

https:// csrc.nist.gov /csrc/media/Projects/olir/documents/submissions/sp800-53r5-to-iso-27001-mapping-2022-OLIR-2023-10-12-UPDATED.xlsx

Informative Reference Information

Status:
Final

Informative Reference Version:
1.0.0

Focal Document Version:
SP 800-53 Rev 5.1.1

Summary:
A crosswalk between the controls within NIST Special Publication (SP) 800-53 Revision 5, SP 800-53B, and ISO/IEC 27001:2022.

Піраміда документації СУІБ

Що організація вимагає і навіщо — для всіх працівників.

Які конкретні правила виконують вимогу — для IT, ІБ і власників процесів.

Хто, що і коли робить — для виконавців.

Як саме виконати крок і чим це довести — для виконавців і аудиторів.

ДОКУМЕНТИ

Якими мають бути політики та інші ВНД

> ГАРНА ПРАКТИКА
>
> Мати «політику про політики»: стандартний шаблон і шлях погодження таких документів.

БАЖАНІ ЯКОСТІ ПОЛІТИКИ

- Потрібна
- Затверджена
- Зрозуміла
- Лаконічна
- Стандартно структурована
- Регулярно переглядається
- Доступна

Приклад: політики ІБ у банку · Навчитись писати гарні політики: PolicyWizard

Як написати свою політику

> Приклади й шаблони — відправна точка, а не готовий документ: вони не знають ваших процесів, інфраструктури й ризик-апетиту. Те саме з політиками від ШІ.

01

Вивчіть 2–3 приклади, щоб зрозуміти структуру й логіку

✓ **Стандартно структурована**

02

Визначте, які вимоги справді стосуються вашої організації

✓ **Потрібна**

03

Напишіть під свій контекст, мовою читачів

✓ **Зрозуміла · Лаконічна**

04

Погодьте з власниками процесів і керівництвом

✓ **Затверджена**

05

Опублікуйте, навчіть персонал, переглядайте щороку

✓ **Доступна · Регулярний перегляд**

II

Управління ризиками

Процес, сценарії, реєстр, оцінка і ризик-апетит

Процес управління ризиками

Події ризику

Розуміння ризику в усіх різне. Перш ніж наповнювати реєстр — політика й поради власникам ризиків.

GRC Lab, The Big Picture · Як розвідка доповнює ризик-менеджмент: CTI vs. Risk Management

Дайте власникам шаблон сценарію

ШАБЛОН

Зловмисник експлуатує **[вразливість / слабкість]**, щоб **[виконати дію]**, що призводить до **[наслідку]**.

ПРИКЛАД

Зловмисник експлуатує **відсутність MFA**, щоб **скомпрометувати обліковий запис користувача**, що призводить до **несанкціонованого доступу до конфіденційних даних**.

ДЕ ДІЮТЬ КОНТРОЛІ

діють на →	Подія загрози	Вразливість	Інцидент	Операції
Превентивні	стримують	зменшують	—	—
Детективні	—	виявляють	виявляють	—
Коригувальні	—	—	зменшують вплив	відновлюють

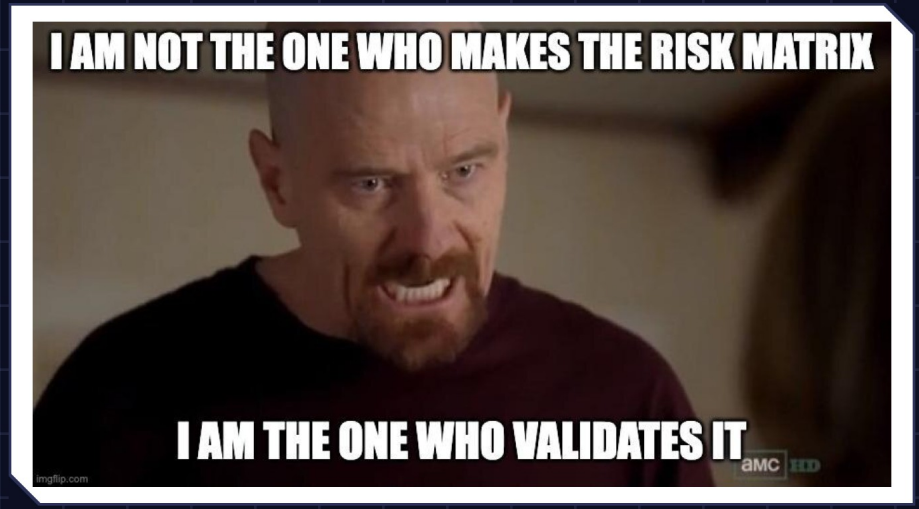
За природою контролі бувають організаційні, людські, фізичні й технологічні.

Джерело: GRC Lab, The Big Picture

Ви – ризик-координатор, а не власник ризику

Зафіксуйте ролі та відповідальності

Якщо ризик реалізується, платити буде власник, тому й рішення приймати має він.

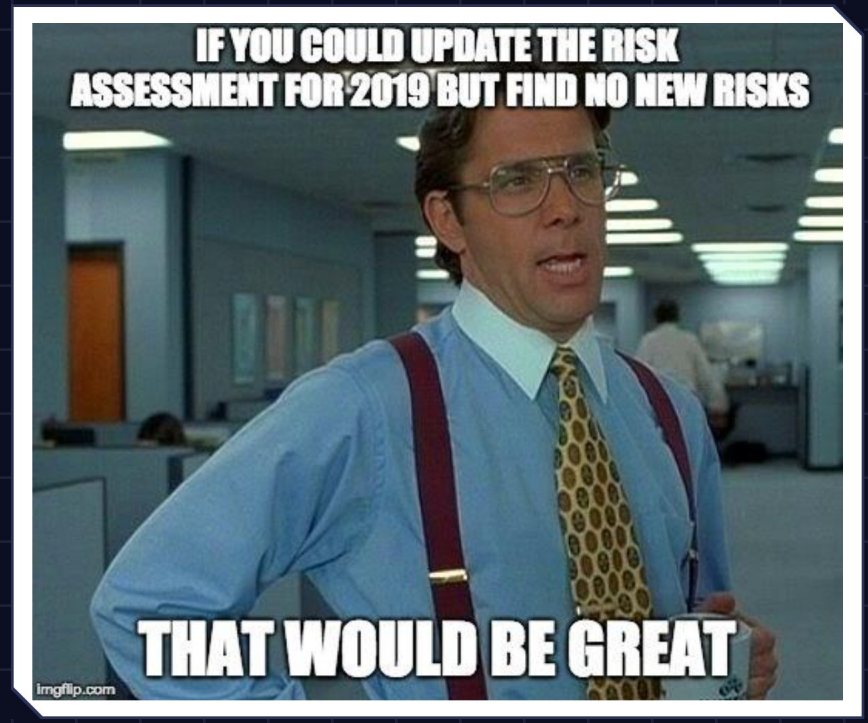


Зібрали ризики – треба оцінити

Вплив — Як сценарій може вплинути на актив і на організацію

Ймовірність — Наскільки сценарій ймовірний — тут допоможе розвідка кіберзагроз

> ⚠ Неправильно сформульований сценарій зведе нанівець усю оцінку.



ПОШИРЕНА ПРОБЛЕМА

Коли кожен ризик – найважливіший

Реєстр без модерації не несе ніякої цінності.

Фахівці з управління ризиком мають модерувати реєстр і адекватність його оцінки та підкріплювати це рішеннями вищого керівництва.

РИЗИК-АПЕТИТ

Скільки ризику ми готові пережити

Ризик-апетит

«Ми можемо це пережити без проблем»

Прийнятний ризик

«Ми можемо це пережити»

Неприйнятний ризик

«Ми не можемо це пережити»

Що ще варто пам’ятати

Ризик-апетит відсіює дрібне

Допомагає не витрачати час на незначні для нас ризики.

Користь — у рішеннях

Оцінка ризиків вартує стільки, скільки корисних і зрозумілих рішень і контролів вона дала.

Вплив можна рахувати в грошах

Див. методологію FAIR.

Моделювання загроз наповнює реєстр

Фреймворки на кшталт OCTAVE і PASTA.

Управління ризиками йде пліч-о-пліч із забезпеченням неперервності бізнесу та подібними дисциплінами.

III

Відповідність

Звідки беруться вимоги, як їх інтегрувати і чим допомагає судова практика

Чому всі так реагують на комплаєнс?

Compliance – відповідність вимогам

Законодавства, регуляторів, клієнтів і партнерів, інших третіх сторін.

Джерела вимог з кібербезпеки

міжнародні й ЄС · Україна · НАТО · стандарти й технічні документи · одна поділка — 2 документи

Разом 223 документи, дані орієнтовно станом на 01.01.2026. Деталі й фільтр за галуззю: GRC One-Stop Shop UA

ВІДПОВІДНІСТЬ

Інтеграція вимог закону зменшує витрати на комплаєнс

ПОШИРЕНА ПРАКТИКА

- «Політика GDPR» + вимоги до захисту даних + посадові обов’язки DPO
- Доведення вимог до виконавців під підпис
- Документи радше для зняття відповідальності, ніж для використання

→

ІНТЕГРОВАНІ СИСТЕМИ УПРАВЛІННЯ

- Одна політика захисту персональних даних
- Виконавці працюють тільки з описаним процесом
- Вимоги законодавства вбудовані в процеси

Як інтегрувати вимоги законів

- Закони можна співвідносити зі стандартами систем управління.
- Це теж тлумачення, тож краще спиратись на меппінги регуляторів або галузевих асоціацій.

ID	DORA	Requirement	NIS2 IT Act	C5:2020	ISO 27001 2022
D.17	Art. 17	Incident management	3.1.1 3.1.2 3.1.3	SIM-01 SIM-02 SIM-03 SIM-04 SIM-05 COS-01	A.5.24 A.5.25 A.5.26 A.5.28 A.6.8
D.18	Art. 18	Classification of incidents and cyber threats	3.4.1 3.4.2	SIM-01	A.5.25
D.19	Art. 19	Incident and Cyber Threat Reporting	3.3.1 3.3.2	OIS-05 SIM-01 SIM-04	A.5.5 A.5.6 A.6.8
D.23	Art. 23 23	Handling payment or safety incidents	- -	- -	- -
D.45	Art. 45	Exchange of information and insights into cyber threats	4.3.3 6.10.2	OIS-05	A.5.5 A.5.6

Tabelle: *Own compilation - as of March 2025 - Without guarantee of completeness and correctness*

ВІДПОВІДНІСТЬ

Закони не тільки зобов’язують, а й захищають

РОЗДІЛ XVI

Кримінальний кодекс України

Кримінальні правопорушення у сфері використання комп’ютерів і мереж

Ст. 361	Несанкціоноване втручання в роботу інформаційних, електронних комунікаційних, інформаційно-комунікаційних систем, електронних комунікаційних мереж
Ст. 362	Несанкціоновані дії з інформацією в комп’ютерах, автоматизованих системах, мережах чи на носіях, вчинені особою, яка має право доступу до неї
Ст. 363	Порушення правил експлуатації комп’ютерів, автоматизованих систем, мереж чи порядку захисту інформації, яка в них обробляється

Куди рухається законодавство України

Адаптація до міжнародних стандартів

Зміцнення правових механізмів реагування на кіберінциденти

Гармонізація законодавства

ГОЛОВНА ДУМКА · СУДОВА ПРАКТИКА

Тлумачення закону буває різне

Досліджуйте судову практику й думки регуляторів, щоб правильно тлумачити та впроваджувати вимоги закону — і уникнути штрафів чи інших проблем.

УКРАЇНА

Єдиний державний реєстр судових рішень

ЄВРОСОЮЗ

Практика — прямо в тексті закону на EUR-Lex

IV

Аудит

Навіщо він, на чому тримається незалежність і хто відповідає за висновки

Що таке аудит?

> Аудит – офіційна перевірка того, чи дотримуються стандарту або набору керівних принципів, чи є записи точними, чи досягаються цільові показники ефективності та результативності.
>
> Глосарій ISACA

IT-аудит | **Фінансовий аудит** | **Операційний аудит**

АУДИТ

Навіщо аудит і на чому він тримається

ПРИЗНАЧЕННЯ

- Продемонструвати відповідність закону
- Виконати вимоги контрагентів — постачальників, клієнтів
- Отримати незалежну оцінку ефективності СУІБ

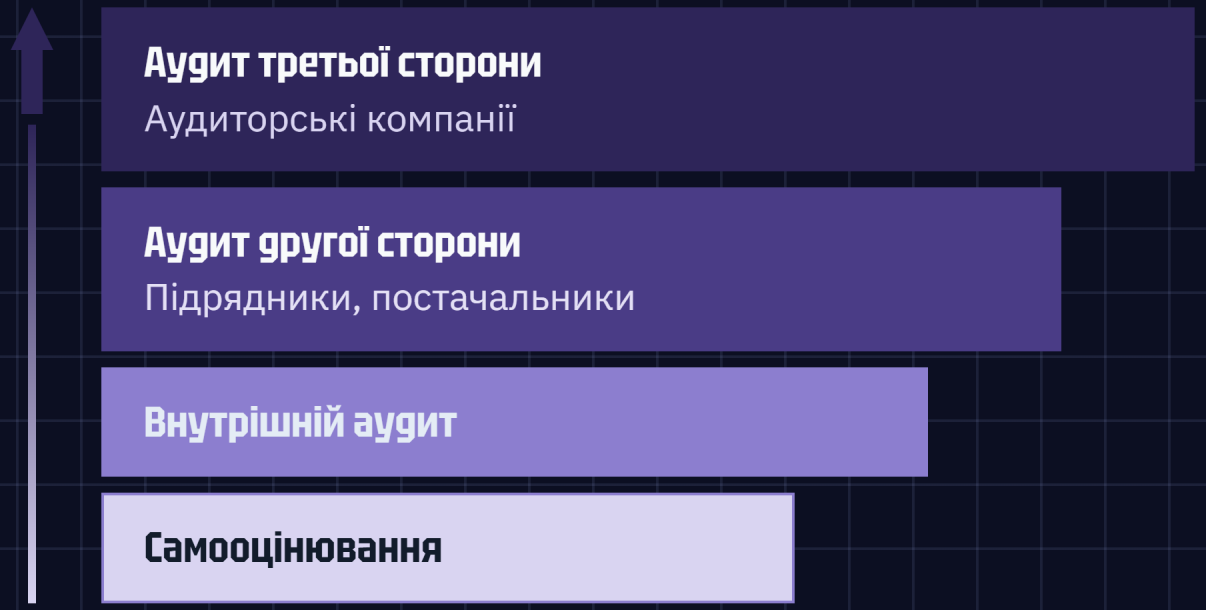
ОСНОВНІ ЯКОСТІ

Незалежність

Доказовість

Об’єктивність

Рівні незалежності аудитора



НЕЗАЛЕЖНІСТЬ

Свобода від обставин, що загрожують об’єктивності чи створюють враження її відсутності. Такі загрози нейтралізують на рівні окремого аудитора, завдання, а також на функціональному й організаційному рівнях.

Незалежність буває у поглядах і в проявах.

ITAF, 3-тє видання

Незалежність тримається на репутації та законі

Закон України **«Про аудит фінансової звітності та аудиторську діяльність»**

Добра репутація аудитора

Протягом двох років поспіль до аудитора не застосовували стягнення три й більше разів і не накладали адміністративних стягнень за порушення цього Закону двічі за 12 календарних місяців.

Конфлікт інтересів

Суперечність між особистими майновими чи немайновими інтересами аудитора та його професійними правами й обов’язками, яка може вплинути на об’єктивність або неупередженість.

Професійна таємниця

Інформація — матеріали, документи тощо, — яка стала відома аудитору під час надання аудиторських послуг.

За висновок аудитор відповідає за законом

> **Аудиторський висновок** — офіційний висновок фахівця з аудиту, що підтверджує довіру до ІС: описує обсяг аудиту, застосовані процедури і те, чи підтверджують результати відповідність критеріям. ITAF, 3-тє видання

Безумовний

Не встановлено жодних порушень — або жодне з них у сукупності не призводить до значного порушення.

Обмежений

Порушення в сукупності призводять до значного порушення, але воно не є суттєвим недоліком.

Негативний

Одне чи кілька значних порушень, які в сукупності призводять до суттєвого недоліку.

АУДИТ · КЕЙС

Arthur Andersen і Enron

ENRON ПЛАТИВ ЩОРОКУ

$20 млн

за аудит — і стільки ж
за консалтинг

1913

Arthur Andersen засновано в Чикаго. 90 років — серед найуспішніших аудиторських компаній світу, у «великій п’ятірці».

Клієнт

Найбільший клієнт х’юстонського офісу — Enron.

Вибір

Аудитори не хотіли втрачати клієнта й готували такий висновок, якого хотів Enron, хоч і бачили невідповідності у звітності.

2001

Співробітники Arthur Andersen почали знищувати документи. «Велика п’ятірка» стала четвіркою.

V

Професія

Навіщо GRC кібербезпеці, хто наймає, які навички й сертифікації потрібні

Як це все стосується кібербезпеки?

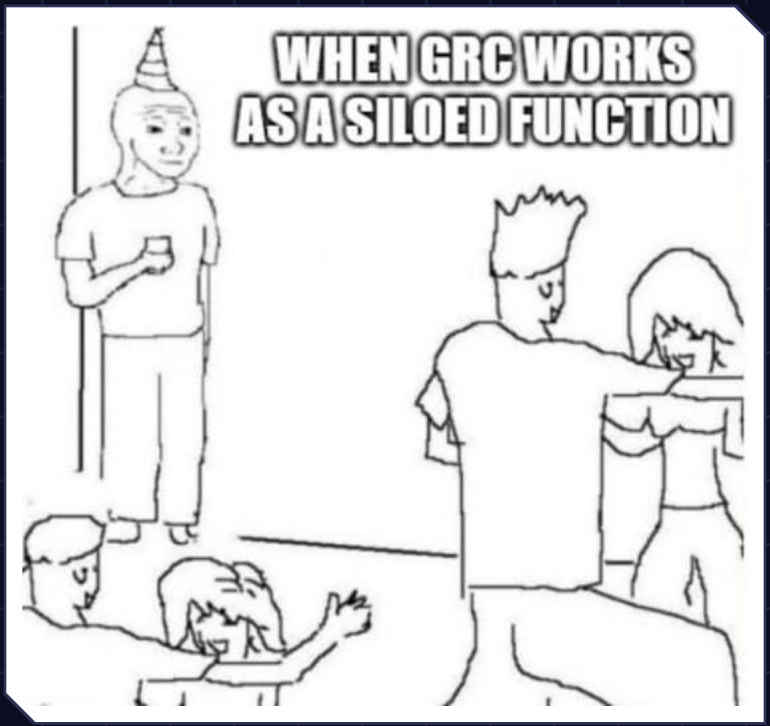
Окрім прямих обов’язків, GRC-підрозділ допомагає:

01 Впровадити мінімально необхідний набір контролів кібербезпеки

02 Злагоджувати внутрішню політику, різницю в думках та інтересах

03 Обґрунтовувати інвестиції в нові інструменти кібербезпеки або розширення штату

04 Узгоджувати бачення проблем і пріоритетів бізнесу та кібербезпеки



ПРОФЕСІЯ

Перспективність

ОСНОВНІ РОБОТОДАВЦІ

Регульовані галузі
КІ, енергетика, банки, держсектор — СУІБ вимагає закон

Експортно-орієнтовані
Напр. IT-аутсорсинг — СУІБ вимагають клієнти

Продуктові компанії
СУІБ — щоб користувачі довіряли продукту

СПІЛЬНОТА

2000 $/міс медіана зарплати Security dou.ua

144+ фахівців у спільноті ISACA Kyiv

28+ відкритих вакансій на момент виступу

Євроінтеграція, вимоги до КІ, розвиток ШІ й переорієнтація на експорт розвиватимуть попит

Необхідні навички

Основні завдання 6

- Відповідність законодавству про захист даних і конфіденційність
- Пошук прогалин у compliance, розробка політик і процедур
- Оцінки впливу на конфіденційність (DPIA)
- Навчання персоналу й культура захисту даних
- Взаємодія з регуляторами, партнерами й командами
- Аудит кібербезпеки та юридичні аспекти ІБ

Ключові навички 5

- Захист даних у бізнес-процесах
- Розробка й впровадження політик кібербезпеки
- Оцінки впливу на конфіденційність
- Комунікація із зацікавленими сторонами
- Відстеження змін у законодавстві й адаптація стратегії

Ключові знання 4

- Законодавство й нормативні акти з кібербезпеки
- Стандарти й фреймворки ІБ: ISO 27001, NIST, GDPR
- Політики кібербезпеки
- Методології оцінки впливу на приватність

ПРОФЕСІЯ

Основні сертифікації

СЬОГОДНІ

CISM	Certified Information Security Manager
CISA	Certified Information Systems Auditor
ISO/IEC 27001	Auditor / Implementer
NIST CSF	Auditor / Implementer

Повна карта: Security Certification Roadmap

З ПРИЦІЛОМ НА МАЙБУТНЄ

Certified GRC Engineer – Practitioner
GRC Engineering Club

«Фахівець з планування політики та стратегії кібербезпеки»
професійний стандарт Держспецзв'язку

ПРОФЕСІЯ · ПИТАННЯ ДО ЗАЛУ

Як думаєте, часто таке трапляється?

Дорога до аудиту, під час нього — і після.

ПРОФЕСІЯ

Майбутнє за GRC Engineering

ПРОБЛЕМИ ТРАДИЦІЙНОГО GRC

- Ручна праця та слабкі результати
- Транзакційні відносини зі стейкхолдерами
- Мислення симптомами, а не причинами
- Сліпа віра у фреймворки
- Compliance як формальність

ПРИНЦИПИ СУЧАСНОГО GRC

- → Shift GRC left
- → GRC як продукт
- → Threat-informed GRC
- → Системне + дизайн-мислення
- → Відкрита спільнота практиків

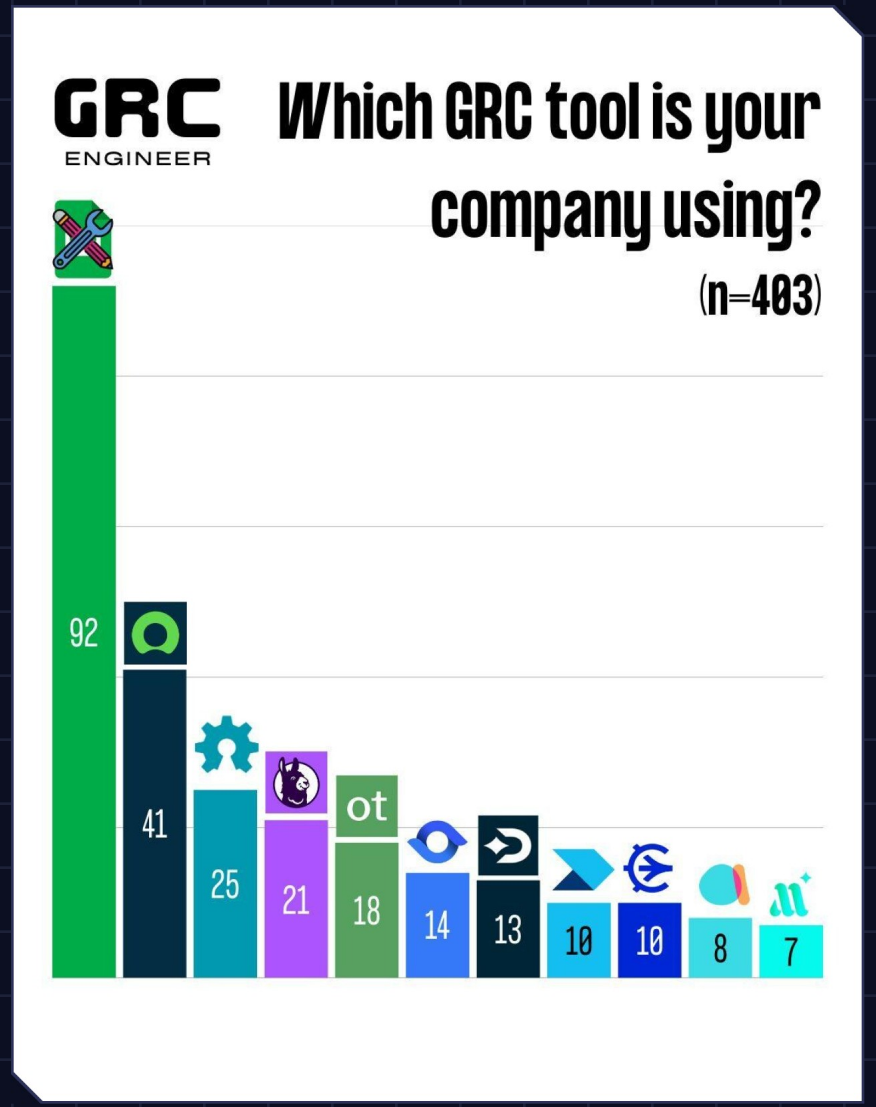
Маніфест і деталі: grc.engineering

Інструменти

Яким GRC-інструментом користується ваша компанія?

Опитування спільноти GRC Engineer, n = 483

Порівняння платформ за відгуками користувачів — G2: Security Compliance



Підсумки

01 Що таке GRC

GRC-підрозділ допомагає організації:

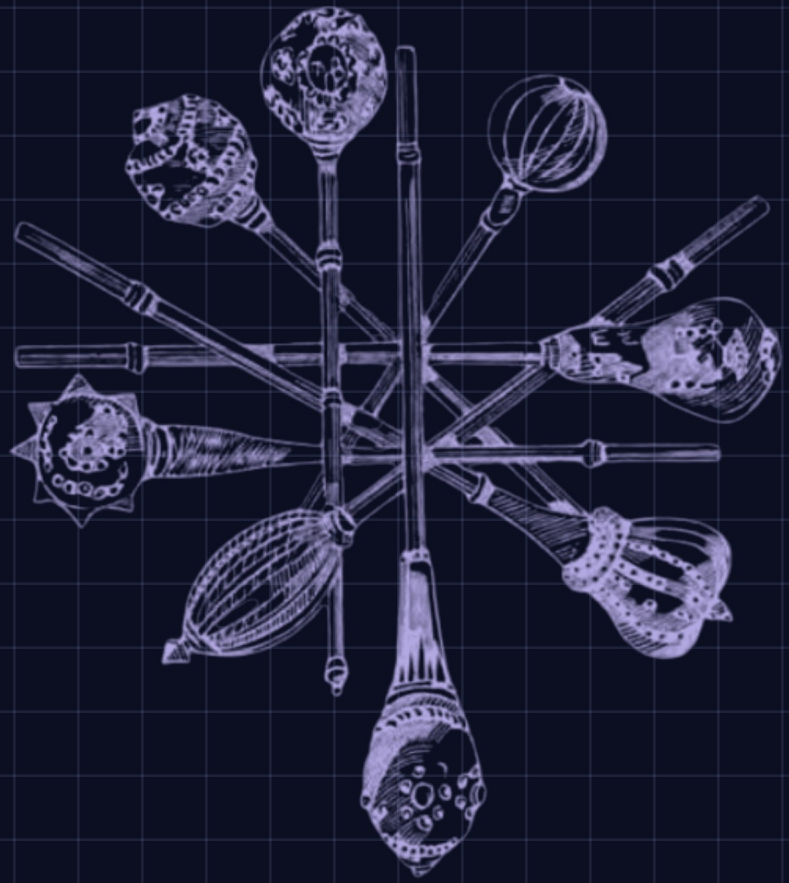
- Виходити на нові ринки й відповідати вимогам законодавства
- Впровадити мінімально необхідний набір контролів — без зайвого
- Розв’язувати внутрішні конфлікти інтересів і узгоджувати пріоритети
- Обґрунтовувати інвестиції в інструменти та людей
- Зблизити бачення бізнесу й кібербезпеки

02 Перспективи

- GRC-фахівці вже добре представлені на ринку України
- Їх ставатиме більше: євроінтеграція (NIS2, DORA, GDPR), розвиток ШІ, зростання IT-експорту й продуктів
- Майбутнє — за GRC Engineering
- Автоматизація та ШІ забирають рутину — і відкривають місце тим, хто будує системи, а не лише заповнює таблиці

НАОСТАНОК

Містобудівні ігри наочно показують принаймні частину ідей, закладених у GRC.



Дякую

Питання й обговорення

Іван Гокін LinkedIn · GitHub

ДОДАТОК

Кого почитати

ТЕМА	КОГО ЧИТАТИ
GRC Engineering	Ayoub Fandi
Критичний погляд на галузь	GRC Destroyer
Управління ризиками	Tony Ridley · Dr. Serhii Babych
Відповідність	Kai Zenner — регулювання ЄС

ДОДАТОК

Де взяти приклади й шаблони

ПРИКЛАДИ УКРАЇНСЬКИХ ПОЛІТИК

ПриватБанк
Політика інформаційної безпеки

Держстат
Політика управління інцидентами

Держстат
Процес управління вразливостями

Держстат
Політика управління ризиками

ШАБЛОНИ

МОЗ
Для медзакладів, на основі NIST CSF

Дія.Бізнес
Кібергігієна для малого бізнесу

SANS
Бібліотека шаблонів політик

ISO 27k Toolkit
Повний набір документів СУІБ

КУРСИ

Legal IT Group
Школа документації з кібербезпеки, українською

PolicyWizard
Information Security Policy Writer

> Усе зібрано в статті «Приклади та шаблони політик СУІБ» — GRC One-Stop Shop UA